

- Claim offer

Task 1 – Understanding RDP Ask AI: Explain: What RDP is Legitimate administrator use cases How attackers abuse RDP Common ransomware campaigns involving RDP Why RDP remains a major SOC detection priority

Task 1 – Understanding RDP

1. What is RDP?

Remote Desktop Protocol (RDP) is a proprietary network protocol developed by Microsoft that allows users to remotely connect to and control another Windows computer over a network.

It provides a full graphical desktop experience, allowing a remote user to interact with the target system as if they were physically sitting in front of it.

Default Port

- **TCP 3389**
- **UDP 3389** (used in newer versions for improved performance)

Components

- **RDP Client** – The computer initiating the connection.
- **RDP Server (Host)** – The computer accepting the remote connection.

Authentication

Modern RDP typically uses:

- Windows Authentication
- Network Level Authentication (NLA)
- Kerberos
- NTLM (fallback in some environments)

2. Legitimate Administrator Use Cases

RDP is widely used by system administrators, helpdesk engineers, and SOC analysts for remote management.

System Administration

- Manage Windows servers
 - Install software
 - Apply security patches
 - Configure services
 - Restart applications
-

Help Desk Support

Support technicians use RDP to:

- Troubleshoot user issues
 - Fix configuration problems
 - Recover deleted files
 - Assist users remotely
-

Server Management

Administrators remotely manage:

- Domain Controllers
 - File Servers
 - SQL Servers
 - Application Servers
-

Cloud Administration

Administrators connect to:

- Virtual Machines
 - Cloud-hosted Windows Servers
 - Remote Lab Environments
-

Incident Response

SOC analysts may use RDP to:

- Collect forensic evidence
 - Inspect running processes
 - Review event logs
 - Isolate compromised systems
 - Validate alerts
-

3. How Attackers Abuse RDP

RDP is one of the most abused remote access technologies because it often provides direct interactive access to systems.

A. Brute Force Attacks

Attackers scan the internet for systems exposing TCP 3389.

They then attempt thousands of username/password combinations until one succeeds.

Example:

Administrator
Password1
Welcome123
Company2025

Detection indicators:

- Numerous failed logins
 - Repeated authentication attempts
 - Logon Type 10 events
 - Multiple source IP addresses
-

B. Credential Stuffing

Attackers use credentials leaked from previous data breaches.

Since many users reuse passwords, valid credentials often work without brute force.

SOC indicators:

- Successful RDP login from an unfamiliar IP
 - Login from unusual geographic locations
 - First-time login behavior
 - Impossible travel scenarios
-

C. Lateral Movement

Once attackers compromise one workstation, they use RDP to move deeper into the network.

Example:

User PC
↓
File Server
↓
SQL Server
↓
Domain Controller

This is common during post-exploitation.

D. Privilege Escalation

After stealing administrator credentials, attackers use RDP to access privileged systems and execute actions with elevated rights.

E. Data Theft

Attackers may use RDP sessions to:

- Search sensitive files
 - Copy databases
 - Download confidential documents
 - Compress data before exfiltration
-

F. Malware Deployment

Through an RDP session, attackers can:

- Upload malware
 - Execute ransomware
 - Disable antivirus
 - Install persistence mechanisms
 - Create scheduled tasks
 - Modify the Windows Registry
-

G. Living off the Land (LOLBins)

Rather than using obvious malware, attackers often execute trusted Windows utilities through RDP, such as:

- PowerShell
- cmd.exe
- certutil.exe
- reg.exe
- schtasks.exe
- wmic.exe

This helps them evade detection.

4. Common Ransomware Campaigns Involving RDP

RDP has been one of the most common initial access vectors in ransomware attacks.

A. SamSam Ransomware

Attack Pattern

Internet
↓
Open RDP
↓
Brute Force
↓
Admin Access
↓
Manual Deployment
↓
Encrypt Entire Network

Characteristics:

- Manual attacks
- Targeted hospitals and municipalities
- Attackers spent days exploring before encryption

B. Dharma (CrySiS) Ransomware

Frequently gained access through:

- Weak RDP passwords
- Exposed RDP services
- Poor password policies

Attackers:

- Logged in manually
- Disabled security software
- Executed ransomware

C. BlueKeep

Although not ransomware itself, this critical RDP vulnerability enabled remote code execution without authentication.

Many ransomware operators attempted to exploit unpatched systems vulnerable to BlueKeep.

D. LockBit

Common workflow:

1. Gain initial access
2. Use stolen credentials

3. Connect via RDP
 4. Disable security tools
 5. Exfiltrate data
 6. Deploy ransomware
-

E. Black Basta

Known to use:

- Stolen VPN credentials
 - Stolen RDP credentials
 - Interactive administrator sessions
 - Lateral movement before encryption
-

F. Conti

Frequently leveraged RDP for:

- Internal reconnaissance
 - Lateral movement
 - Privilege escalation
 - Domain-wide ransomware deployment
-

5. Why RDP Remains a Major SOC Detection Priority

SOC teams prioritize RDP monitoring because it provides attackers with interactive access that closely resembles legitimate administrator activity.

High Initial Access Risk

Exposed RDP services remain a common entry point through brute-force attacks, password spraying, and stolen credentials.

Detection examples:

- Repeated failed logins
 - External connections to TCP 3389
 - Successful logins after multiple failures
-

Enables Lateral Movement

Once inside a network, attackers often use RDP to move between systems using valid accounts.

Detection examples:

- New RDP connections between internal hosts
 - Administrative accounts accessing unusual systems
 - Sudden increase in Logon Type 10 events
-

Interactive Hands-on-Keyboard Attacks

Unlike automated malware, RDP allows attackers to manually explore systems, execute commands, and disable defenses.

SOC teams should monitor for:

- Interactive logons
 - Process execution during RDP sessions
 - Registry changes
 - Scheduled task creation
 - Security tool tampering
-

Common in Ransomware Operations

Many ransomware incidents include RDP activity during one or more phases:

- Initial access
- Lateral movement
- Privilege escalation
- Data exfiltration
- Ransomware deployment

Early detection of suspicious RDP activity can help stop an attack before encryption occurs.

Blends with Legitimate Administration

Because administrators legitimately use RDP, attackers can hide within normal operations.

Behavioral analytics and context are therefore essential, such as:

- Logins outside business hours
 - Unusual source locations
 - First-time access to critical servers
 - Abnormal administrative activity
-

SOC Analyst Key Takeaways

Topic	Key Points
What is RDP?	Microsoft's protocol for remotely controlling Windows systems over the network.
Default Port	TCP/UDP 3389
Legitimate Uses	Remote administration, help desk support, server management, cloud administration, incident response
Common Abuse	Brute force, credential stuffing, lateral movement, privilege escalation, malware deployment, data theft
Frequently Associated Threats	SamSam, Dharma (CrySiS), LockBit, Black Basta, Conti; BlueKeep enabled RDP-based compromise on vulnerable systems
Why SOCs Monitor It	RDP is commonly used for initial access, lateral movement, interactive attacker activity, and ransomware deployment, while also blending with legitimate administrative behavior.

Task 3 – Detection Engineering (RDP)

Detection 1 – Multiple Failed RDP Logins

Objective

Detect repeated failed Remote Desktop authentication attempts that may indicate brute-force or password-spraying attacks.

Detection Logic

Trigger when:

- **Event ID:** 4625 (Failed Logon)
- **Logon Type:** 10 (Remote Interactive)
- More than **10 failed logins**
- Same source IP
- Same destination host
- Within **5 minutes**

Example Logic

IF

Event ID = 4625

AND Logon Type = 10

AND Failed Attempts >= 10

WITHIN 5 Minutes

GROUP BY Source IP + Destination Host

THEN

Alert

Severity

High

MITRE ATT&CK

- T1110 – Brute Force

False Positives

- User forgot password
- Expired passwords
- Misconfigured applications
- Helpdesk troubleshooting
- Credential synchronization issues

Tuning Recommendations

- Exclude trusted vulnerability scanners
- Whitelist approved monitoring systems
- Increase thresholds for noisy environments
- Prioritize external IP addresses
- Correlate with firewall and VPN logs

Detection 2 – Successful Login After Brute Force

Objective

Detect successful RDP authentication immediately following multiple failed login attempts.

Detection Logic

Trigger when:

- Five or more **4625** events
- Followed by **4624**
- Logon Type **10**

- Same username
- Same source IP
- Within **10 minutes**

Example Logic

4625 x5
↓
4625 x5
↓
4624 Success
(Logon Type 10)

Severity

Critical

MITRE ATT&CK

- **T1110 – Brute Force**
- **T1078 – Valid Accounts**

False Positives

- User mistyped password several times
- Password reset followed by login
- Account unlock events

Tuning Recommendations

- Increase failure threshold if necessary
- Prioritize external source IPs
- Escalate if privileged accounts are involved
- Correlate with geolocation and MFA events

Detection 3 – First-Time RDP Login

Objective

Detect users logging in via RDP to a host for the first time, which may indicate lateral movement or account misuse.

Detection Logic

Trigger when:

- Event ID **4624**
- Logon Type **10**
- Successful RDP login

- User has **no previous RDP login history** to the destination host within the last **30–90 days**

Example Logic

IF

Event ID = 4624

AND Logon Type = 10

AND

(User → Destination Host)

NOT Seen Before

Generate Alert

Severity

Medium

Increase to **High** if:

- Sensitive server
- Domain Controller
- Privileged account
- External source IP

MITRE ATT&CK

- **T1021.001 – Remote Services: Remote Desktop Protocol**
- **T1078 – Valid Accounts**

False Positives

- New employee
- New server deployment
- Planned administrative work
- Role changes

Tuning Recommendations

- Maintain a 30–90 day RDP baseline
- Ignore approved onboarding activities
- Correlate with asset criticality
- Use UEBA to identify abnormal first-time access

Detection 4 – Administrator RDP Login

Objective

Detect RDP sessions initiated using privileged or administrative accounts.

Detection Logic

Trigger when:

- Event ID **4624**
- Logon Type **10**
- User belongs to:
 - Domain Admins
 - Enterprise Admins
 - Server Admins
 - Local Administrators
- OR matches a privileged account list

Example Logic

IF

Event ID = 4624

AND Logon Type = 10

AND User IN

Privileged Accounts

Generate Alert

Severity

High

Increase to **Critical** if:

- External IP
- New device
- Outside business hours
- Domain Controller accessed

MITRE ATT&CK

- **T1078 – Valid Accounts**
- **T1021.001 – Remote Services: Remote Desktop Protocol**

False Positives

- Routine server maintenance
- Helpdesk remote support
- Scheduled patching
- Approved emergency administration

Tuning Recommendations

- Maintain an accurate privileged account inventory
 - Whitelist approved jump servers
 - Suppress alerts during maintenance windows
 - Correlate with MFA, device health, and login location
-

Detection 5 – RDP Followed by PowerShell Execution

Objective

Detect PowerShell execution immediately after an RDP login, a common pattern during interactive attacker activity.

Detection Logic

Trigger when:

- Successful RDP login
 - Event ID **4624**
 - Logon Type **10**
- Followed within **5 minutes** by:
 - **powershell.exe**
 - **pwsh.exe**
- Optionally increase confidence if PowerShell uses:
 - -EncodedCommand
 - -ExecutionPolicy Bypass
 - -WindowState Hidden

Example Logic

4624
(Logon Type 10)
↓
powershell.exe
WITHIN 5 Minutes

Generate Alert

Data Sources

- Windows Security Logs
- Sysmon Event ID 1 (Process Creation)
- Microsoft Defender XDR
- Microsoft Sentinel

Severity

High

Increase to **Critical** if PowerShell is encoded or followed by credential dumping, persistence changes, or network connections.

MITRE ATT&CK

- **T1021.001 – Remote Services: Remote Desktop Protocol**
- **T1059.001 – Command and Scripting Interpreter: PowerShell**

False Positives

- Administrators performing legitimate maintenance
- Automation scripts
- Software deployment tools
- IT troubleshooting sessions

Tuning Recommendations

- Focus on suspicious PowerShell arguments (-EncodedCommand, -NoProfile, -ExecutionPolicy Bypass)
- Correlate with child processes, registry changes, or outbound connections
- Exclude known automation accounts and management servers
- Prioritize activity on critical assets

Detection Engineering Summary

Detection	Detection Logic	Severity	MITRE ATT&CK	Key Tuning
Multiple Failed RDP Logins	≥10 failed Event ID 4625 (Logon Type 10) within 5 minutes	High	T1110 – Brute Force	Exclude scanners, tune thresholds, prioritize external IPs
Successful Login After Brute Force	Multiple 4625 events followed by 4624 success	Critical	T1110, T1078 – Valid Accounts	Correlate with source IP, MFA, and privileged accounts

Detection	Detection Logic	Severity	MITRE ATT&CK	Key Tuning
First-Time RDP Login	First observed 4624 (Logon Type 10) for a user–host pair	Medium–High	T1021.001, T1078	Build historical baselines and use UEBA
Administrator RDP Login	4624 (Logon Type 10) by a privileged account	High–Critical	T1078, T1021.001	Whitelist jump servers and correlate with login context
RDP Followed by PowerShell	4624 (Logon Type 10) followed by powershell.exe within 5 minutes	High–Critical	T1021.001, T1059.001 – PowerShell	Detect encoded commands and correlate with subsequent malicious activity

Task 4 – Detection Tuning Scenario: A SOC receives hundreds of RDP alerts every day. Ask AI: Why? Common false positives? How would you tune the rules? Before vs after comparison Best practices

Task 4 – Detection Tuning

Scenario

A Security Operations Center (SOC) receives **hundreds of RDP alerts every day**, making it difficult for analysts to identify genuine threats. This results in alert fatigue, slower investigations, and an increased risk of missing real attacks.

The goal of detection tuning is to **reduce false positives while preserving the ability to detect malicious RDP activity**.

1. Why Is the SOC Receiving Hundreds of RDP Alerts?

There are several common reasons:

A. Legitimate Administrator Activity

System administrators, helpdesk engineers, and IT support teams frequently use RDP to:

- Manage servers

- Troubleshoot user systems
- Install software
- Perform patching
- Conduct maintenance

Without context, every administrative RDP session may generate an alert.

B. Password Mistypes

Users often:

- Forget passwords
- Type incorrect passwords multiple times
- Use outdated cached credentials

These generate repeated **Event ID 4625** (failed login) events that resemble brute-force attacks.

C. Automated Management Tools

Various enterprise tools use RDP or remote logon mechanisms for:

- Software deployment
- Patch management
- Asset management
- Remote administration

These can generate numerous legitimate authentication events.

D. Vulnerability Scanners

Internal scanners may repeatedly test authentication or connectivity, resulting in many failed login events from trusted scanning systems.

E. Monitoring and Backup Services

Monitoring agents or backup solutions may authenticate regularly to remote systems, creating repetitive login events.

F. Scheduled Maintenance

Routine activities such as:

- Windows Updates

- Patch Tuesday deployments
- Server reboots
- Overnight maintenance

can trigger large volumes of RDP-related alerts.

G. Shared Administrative Accounts

Organizations sometimes use shared administrator accounts across multiple systems, causing frequent RDP logins that appear suspicious without additional context.

2. Common False Positives

Alert	Common False Positive
Multiple failed logins	User entered the wrong password several times
Successful login after failures	User remembered the correct password
Administrator RDP login	Planned server maintenance
After-hours login	On-call administrator performing emergency work
New source IP	User connected through a corporate VPN or a different office
First-time RDP login	New employee or newly assigned server
RDP followed by PowerShell	Administrator executing maintenance scripts
External RDP login	Approved third-party vendor or managed service provider

3. How Would You Tune the Rules?

Tune 1 – Increase Thresholds

Before

Alert after:

3 failed logins

After

Alert after:

10–15 failed logins within 5 minutes

Benefit

- Reduces alerts from simple typing mistakes.
 - Still detects brute-force attacks.
-

Tune 2 – Exclude Approved Administrative Systems

Create an allowlist for:

- Jump servers
- Bastion hosts
- IT management servers
- Helpdesk systems

Benefit

Routine administrative access no longer generates unnecessary alerts.

Tune 3 – Exclude Service Accounts

Service accounts often:

- Run scheduled tasks
- Perform backups
- Execute automated jobs

Maintain an inventory of approved service accounts and exclude them where appropriate.

Tune 4 – Build User Baselines

Track:

- Normal login times
- Typical source IPs
- Common devices
- Frequently accessed hosts

Only alert when behavior deviates significantly from the established baseline.

Tune 5 – Correlate Multiple Events

Instead of alerting on a single RDP login, require additional suspicious behavior, such as:

RDP Login



PowerShell



Encoded Command



Registry Modification

This greatly increases detection confidence.

Tune 6 – Focus on High-Risk Assets

Increase alert priority for:

- Domain Controllers
- Database servers
- Critical application servers
- Backup servers

Lower the priority for standard employee workstations.

Tune 7 – Prioritize External Access

Separate:

- Internal RDP sessions
- External RDP sessions

External RDP activity generally carries higher risk and should receive higher priority.

Tune 8 – Suppress During Maintenance Windows

Suppress or lower alert severity during:

- Planned patching
 - Scheduled upgrades
 - Approved maintenance periods
-

Tune 9 – Risk-Based Alerting

Assign higher severity when multiple risk factors occur together, for example:

- Privileged account
- New source IP
- Outside business hours

- Sensitive server
- Multiple failed logins before success

4. Before vs After Comparison

Category	Before Tuning	After Tuning
Failed login threshold	3 attempts	10–15 attempts in 5 minutes
Administrator logins	Every login alerts	Only unusual or high-risk administrator logins
New source IP	Every new IP alerts	Trusted VPNs and corporate networks excluded
After-hours access	Every login alerts	Approved on-call and maintenance windows excluded
PowerShell after RDP	All PowerShell executions alert	Focus on suspicious arguments (e.g., -EncodedCommand, -ExecutionPolicy Bypass)
Service accounts	Alerts generated	Approved service accounts excluded
Asset context	Same priority for all systems	Critical assets receive higher priority
Correlation	Single-event alerts	Multi-event correlation (RDP + PowerShell + Registry + Network)
Hundreds of alerts Analyst workload daily		Fewer, higher-confidence alerts

5. Best Practices for RDP Detection Tuning

1. Understand Normal Behavior

- Establish baselines for users, devices, login times, and source IPs before tuning.

2. Use Context

- Include asset criticality, user roles, privileged status, geolocation, and device trust when evaluating alerts.
- 3. Correlate Related Events**
 - Combine RDP activity with process creation, PowerShell execution, registry changes, network connections, or credential access to improve confidence.
 - 4. Maintain Allowlists Carefully**
 - Regularly review approved jump servers, service accounts, VPN gateways, and administrative hosts to avoid stale exclusions.
 - 5. Prioritize High-Risk Activity**
 - Increase severity for privileged accounts, external logins, first-time access to sensitive systems, and after-hours activity.
 - 6. Review and Tune Continuously**
 - Measure false-positive rates, gather analyst feedback, and adjust thresholds as the environment evolves.
 - 7. Leverage UEBA**
 - Use User and Entity Behavior Analytics to detect deviations from normal behavior instead of relying only on static thresholds.
 - 8. Validate Through Threat Hunting**
 - Periodically test detections using simulated attacks (e.g., RDP brute force, lateral movement, and PowerShell execution) to ensure tuning has not reduced detection coverage.

SOC Analyst Takeaways

Area	Key Recommendation
Primary Cause of Alert Volume	Legitimate administrative activity, user errors, automation, and scheduled maintenance
Reduce False Positives	Raise thresholds, use allowlists, exclude service accounts, and account for maintenance windows
Improve Detection Quality	Correlate RDP with PowerShell, registry changes, network activity, and asset criticality
Focus on Risk	Prioritize external logins, privileged accounts, unusual behavior, and critical systems

Area	Key Recommendation
Long-Term Strategy	Continuously review detection performance, update baselines, and use behavioral analytics to keep rules effective without overwhelming analysts

Mini Investigation Scenario Scenario A Windows server generates the following detections: Twenty failed RDP login attempts from 203.0.113.25 Successful Administrator RDP login from the same IP five minutes later PowerShell launches shortly after login New local administrator account created Outbound HTTPS connection established Scheduled Task created for persistence Ask AI to: Correlate all detections into one attack timeline. Explain why each detection triggered. Identify the attacker's objectives. Map activity to MITRE ATT&CK. Assign severity. Recommend containment actions. Suggest additional detections.

Mini Investigation Scenario – RDP Attack Investigation

1. Executive Summary

A Windows server experienced a **high-confidence compromise** that began with an **RDP brute-force attack** against the built-in **Administrator** account. After approximately **20 failed login attempts**, the attacker successfully authenticated from the same external IP address (**203.0.113.25**).

Following the successful login, the attacker executed **PowerShell**, created a **new local administrator account** for persistent privileged access, established an **outbound HTTPS connection** (likely to a Command-and-Control server), and created a **Scheduled Task** to maintain persistence across system reboots.

This sequence closely matches the tactics commonly observed in **hands-on-keyboard ransomware** and **post-exploitation intrusion** campaigns.

2. Attack Timeline

Time	Detection	Analysis
T0	20 failed RDP login attempts from 203.0.113.25	Brute-force/password guessing against the Windows server.
T+5 min	Successful Administrator RDP login from the same IP	Attacker successfully authenticated using valid credentials after repeated failures.

Time	Detection	Analysis
T+6 min	PowerShell launched	Interactive command execution for reconnaissance, payload download, or system modification.
T+8 min	New local administrator account created	Persistence established by creating a backup administrative account.
T+10 min	Outbound HTTPS connection	Likely communication with an external C2 server, payload download, or data exfiltration.
T+12 min	Scheduled Task created	Persistence mechanism to automatically execute commands or malware after reboot or on a schedule.

3. Detection Correlation

Detection 1 – Multiple Failed RDP Logins

Why it triggered

- Twenty failed authentication attempts
- Same source IP
- Same destination server
- Logon Type 10 (Remote Interactive)

Interpretation

Strong indicator of an RDP brute-force attack.

Detection 2 – Successful Administrator Login

Why it triggered

- Successful Event ID 4624
- Administrator account
- Same source IP that previously generated multiple failures

Interpretation

The attacker likely guessed or obtained the correct Administrator password.

Detection 3 – PowerShell Execution

Why it triggered

PowerShell executed immediately after interactive RDP access.

Interpretation

This behavior is commonly associated with:

- System reconnaissance
 - Downloading malware
 - Credential theft
 - Disabling security tools
 - Running attacker scripts
-

Detection 4 – Local Administrator Account Created

Why it triggered

A new local user was added and assigned administrative privileges.

Interpretation

This provides the attacker with persistent privileged access even if the original compromised credentials are changed.

Detection 5 – Outbound HTTPS Connection

Why it triggered

The server initiated a new encrypted outbound connection shortly after the compromise.

Interpretation

Possible purposes include:

- Command-and-Control (C2)
 - Downloading additional malware
 - Data exfiltration
 - Beaconsing to attacker infrastructure
-

Detection 6 – Scheduled Task Creation

Why it triggered

A new Scheduled Task was created following the attack sequence.

Interpretation

Scheduled Tasks are a common persistence technique that enables malware or attacker commands to run automatically after reboot or at defined intervals.

4. Attacker Objectives

Based on the observed sequence, the attacker's likely objectives were:

Initial Access

Gain entry into the server through RDP using brute-force or password guessing.

Establish Interactive Control

Obtain an Administrator desktop session for manual, hands-on control.

Execute Commands

Use PowerShell to:

- Enumerate the environment
 - Download tools
 - Execute malicious scripts
 - Prepare the system for further compromise
-

Maintain Persistence

Ensure continued access by:

- Creating a new administrator account
 - Registering a Scheduled Task
-

Communicate with External Infrastructure

Use HTTPS to:

- Receive commands
 - Download payloads
 - Exfiltrate data
 - Maintain C2 communications
-

Prepare for Further Attack Stages

Potential next steps could include:

- Lateral movement

- Credential dumping
- Data theft
- Ransomware deployment

5. MITRE ATT&CK Mapping

Attack Stage	MITRE Technique	Technique ID
Brute-force RDP login	Brute Force	T1110
Successful Administrator login	Valid Accounts	T1078
Remote desktop access	Remote Services: Remote Desktop Protocol	T1021.001
PowerShell execution	Command and Scripting Interpreter: PowerShell	T1059.001
New administrator account	Create Account: Local Account	T1136.001
Scheduled Task persistence	Scheduled Task/Job	T1053.005
HTTPS communication	Application Layer Protocol: Web Protocols	T1071.001

6. Severity Assessment

Overall Severity: Critical

Justification

This incident demonstrates multiple stages of a successful attack:

- Successful external compromise
- Administrator-level access
- Post-exploitation activity
- Persistence established
- Possible Command-and-Control communication
- High likelihood of continued malicious activity

Immediate incident response is required.

7. Recommended Containment Actions

Immediate Actions

1. **Isolate the affected server** from the network.
2. **Terminate the active RDP session** and any malicious processes.
3. **Block the source IP (203.0.113.25)** at firewalls and perimeter security devices.
4. **Disable or reset the compromised Administrator account** and rotate privileged credentials.
5. **Remove the unauthorized local administrator account** after preserving forensic evidence.
6. **Disable and preserve the malicious Scheduled Task** for investigation.
7. **Terminate suspicious PowerShell processes** and collect execution logs.
8. **Block the outbound HTTPS destination** if identified as malicious.
9. **Collect forensic artifacts**, including:
 - Security Event Logs
 - Sysmon logs
 - PowerShell Operational logs
 - Scheduled Task configuration
 - Network connection records
 - Memory capture (if feasible)
10. **Scan for additional compromise** across the environment, including lateral movement and persistence on other systems.

8. Suggested Additional Detections

Detection	Purpose
Successful RDP login after multiple failed logins	Detect likely brute-force success
First-time RDP login to a server	Identify unusual remote access
Privileged account RDP login	Monitor high-value administrative access

Detection	Purpose
External RDP login from unfamiliar IP	Detect suspicious remote access
PowerShell with -EncodedCommand or -ExecutionPolicy Bypass	Identify obfuscated or suspicious script execution
Local administrator account creation	Detect unauthorized privilege establishment
Addition to the Administrators group	Detect privilege escalation
Scheduled Task creation or modification	Detect persistence mechanisms
New outbound HTTPS connection after RDP login	Identify potential C2 or data exfiltration
Multiple post-login events (RDP → PowerShell → Account Creation → Scheduled Task) Correlate attack chains for high-confidence alerts	

9. SOC Analyst Conclusion

This investigation reveals a **complete attack chain** beginning with an **RDP brute-force attack** and progressing through **successful authentication, interactive PowerShell execution, persistence via a new administrator account and Scheduled Task, and outbound HTTPS communication**. The sequence strongly indicates an active compromise consistent with modern ransomware or hands-on-keyboard intrusion techniques.

The combination of **credential compromise, privileged remote access, command execution, persistence**, and **external communications** warrants a **Critical** incident classification and immediate containment. Rapid isolation, credential rotation, forensic preservation, and environment-wide hunting are essential to prevent lateral movement, data exfiltration, or ransomware deployment.